

Cloud Security



Cloud Security

- Cloud Computing Roles
- Cryptography in Cloud
- Cloud Data Security
- Data Classification
- Data Identification
- Data Privacy
- Defined controls for PII
- Identity & Access Management

Labs

- Students to login to Microsoft Azure and explore the different features of Security Center

Cloud Computing Roles

Security responsibilities are divided based on the cloud service model:

- **IaaS (Infrastructure as a Service)**

- *Provider:* Physical data centers, hardware, networking, hypervisors
- *Customer:* OS security, patching, firewalls, IAM, applications, data

- **PaaS (Platform as a Service)**

- *Provider:* Infrastructure, OS, runtime, middleware
- *Customer:* Application security, data protection, IAM

- **SaaS (Software as a Service)**

- *Provider:* End-to-end stack including application security
- *Customer:* User access management, data governance, endpoint security



Core Security Roles in Cloud Computing

- **Identity and Access Management (IAM)**
 - MFA, SSO, RBAC
- **Data Security**
 - Data encryption at rest, in transit and in use, KMS, DR & recovery
- **Network Security**
 - vNet, subnet, NSG, NACLs, NGFW, WAF, DDoS protection
- **Application Security**
 - Runtime protection, patch management, SDLC & DevSecOps
- **Monitoring, Logging, and Incident Response**
 - Central logging, SIEM integration and alerting



Cryptography in Cloud

- Cryptography is a foundational security control in cloud computing that ensures confidentiality, integrity, authenticity, and non-repudiation of data and communications across cloud environments.
- Cryptography protects cloud assets by:
 - Preventing *unauthorized data access*
 - *Securing data transmission* over public networks
 - Ensuring *data integrity* and *authenticity*
 - Supporting *regulatory and compliance requirements*



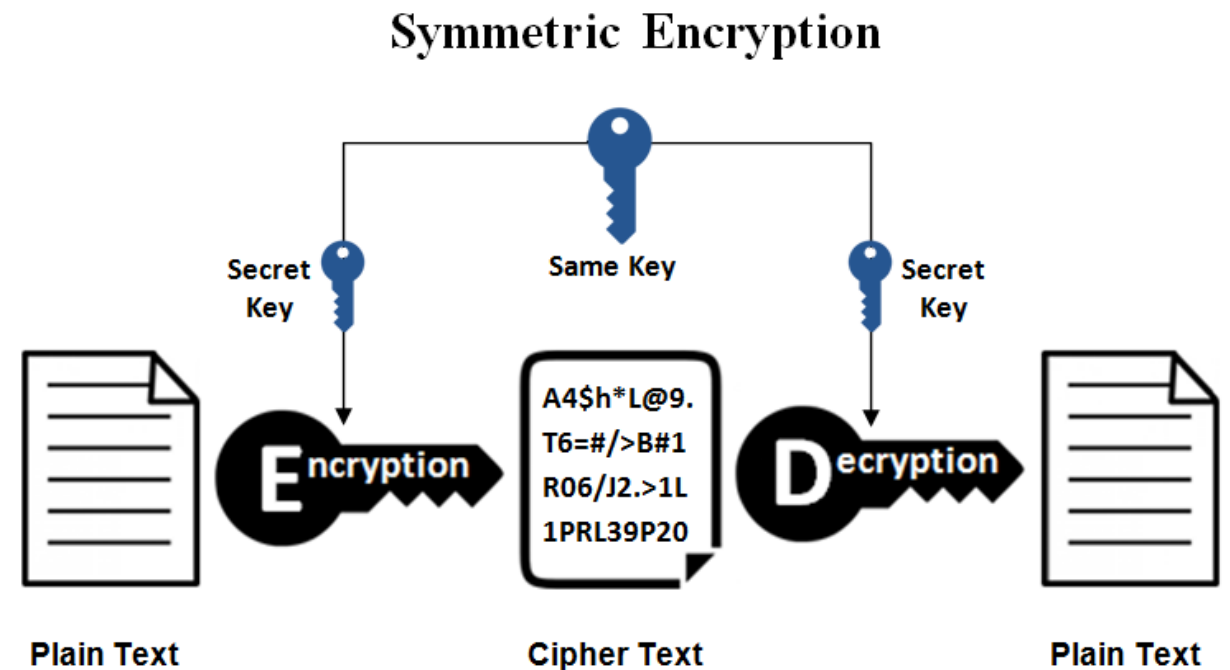
Key Cryptographic Objectives

Objective	Description
Confidentiality	Data is readable only by authorized entities
Integrity	Data cannot be altered without detection
Authentication	Verifies identity of users and services
Non-repudiation	Prevents denial of performed actions

Types of Cryptography Used in Cloud

1. Symmetric Encryption

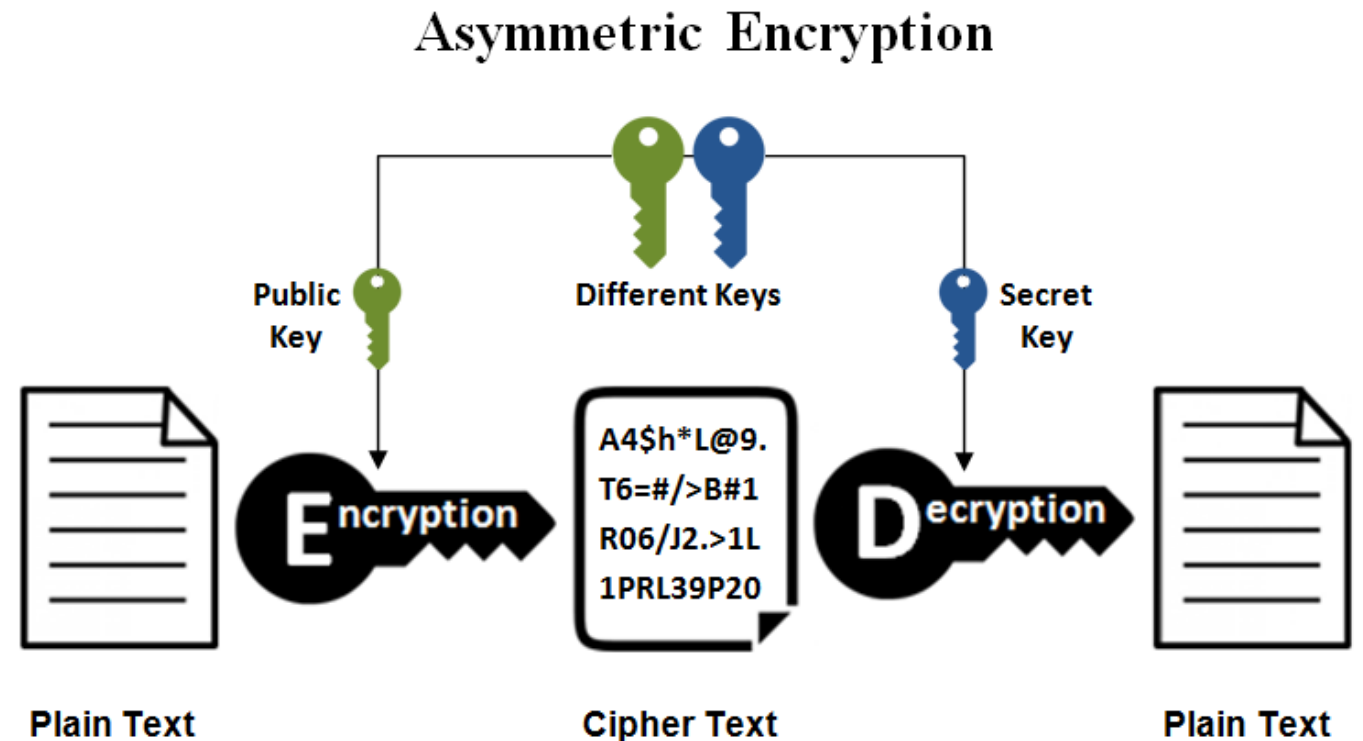
- Same key for *encryption* and *decryption*
- *Fast* and *efficient* for large data volumes
- Common algorithms: *AES-128/256*
- Use cases:
 - Data at rest (disks, databases, backups)
 - Temporary session encryption



Types of Cryptography Used in Cloud

2. Asymmetric Encryption

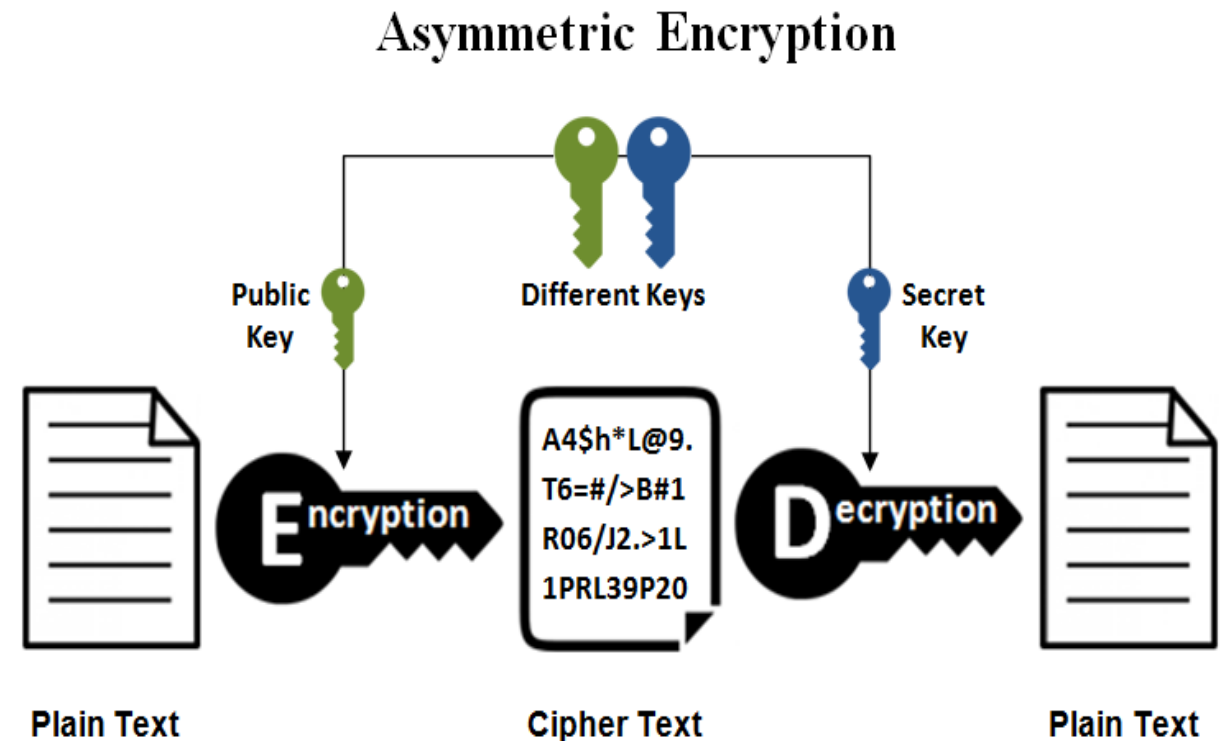
- Uses *public-private key pairs*
- *Slower* but *more secure* for key exchange
- Common algorithms: *RSA*, *ECC*
- Use cases:
 - Key exchange
 - Digital certificates
 - Secure authentication



Types of Cryptography Used in Cloud

3. Hashing

- *One-way* cryptographic function
- Ensures *integrity*, not confidentiality
- Common algorithms: *SHA-256*, *SHA-3*
- Use cases:
 - Password storage
 - Integrity verification
 - Digital signatures



Cloud Data Security

- Cloud Data Security refers to the policies, technologies, and controls used to protect data stored, processed, and transmitted in cloud environments from unauthorized access, breaches, loss, and corruption.
- It is a critical pillar of overall cloud security and operates under the *shared responsibility model*.
- Objectives of Cloud Data Security
 - **Confidentiality:** Prevent unauthorized data access
 - **Integrity:** Ensure data accuracy and prevent tampering
 - **Availability:** Ensure data is accessible when required
 - **Privacy & Compliance:** Meet regulatory and legal requirements



Shared Responsibility Model (Data Perspective)

Cloud Model	Provider Responsibility	Customer Responsibility
IaaS	Physical security, infrastructure	OS security, data encryption, access control
PaaS	Infrastructure, runtime security	Application logic, data protection
SaaS	Application and platform security	Data usage, access governance

Key Components of Cloud Data Security

- **Data Classification**

- Identify data sensitivity (Public, Internal, Confidential, Restricted)
- Enables appropriate security controls

- **Encryption**

- Data at Rest: Disk, database, and object storage encryption
- Data in Transit: TLS/SSL, VPN, HTTPS
- Data in Use: Confidential computing, secure enclaves

- **Key Management**

- Centralized Key Management Services (KMS)
- Customer-managed keys (CMK) vs provider-managed keys
- Hardware Security Modules (HSM) for high assurance



Other Components of Cloud Data Security

Identity and Access Control

- Role-Based Access Control (RBAC)
- Least privilege principle
- Multi-Factor Authentication (MFA)
- Just-in-time (JIT) access

Data Loss Prevention (DLP)

- Detect and prevent data exfiltration
- Monitor sensitive data movement
- Enforce data sharing policies

Backup, Recovery, and Resilience

- Automated backups
- Cross-region replication
- Disaster recovery planning (RPO/RTO)
- Protection against ransomware

Monitoring, Logging, and Auditing

- Data access logging
- Integration with SIEM/SOAR
- Real-time alerts on suspicious activity
- Continuous compliance monitoring

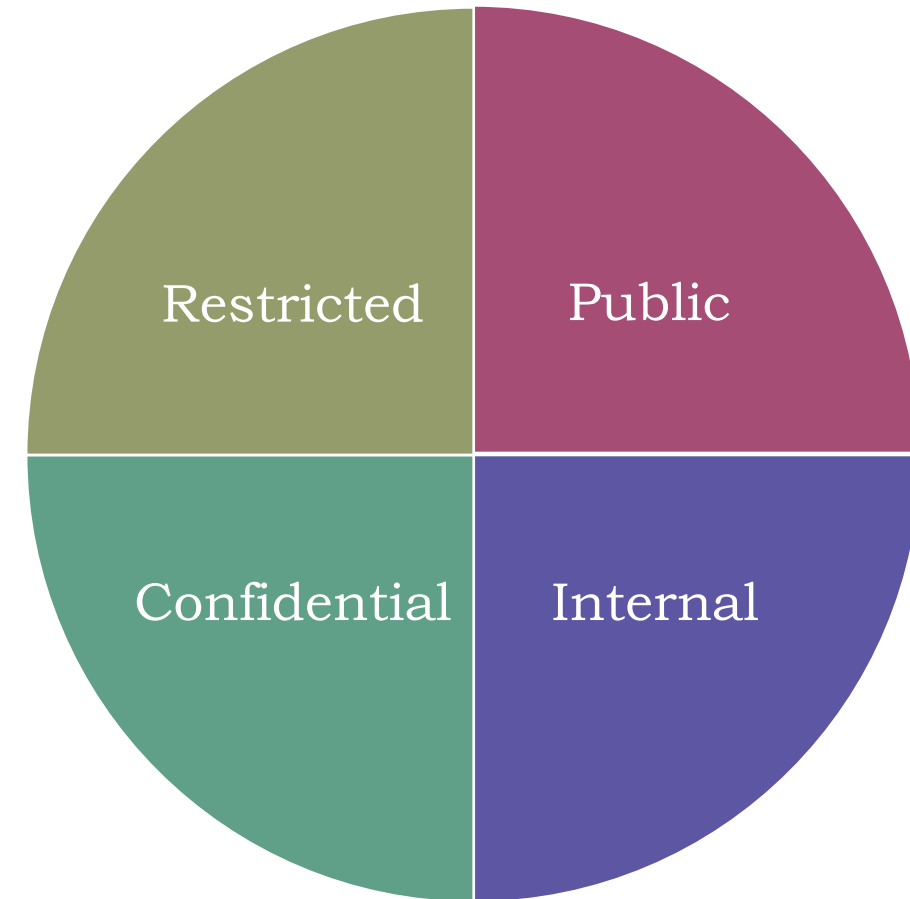
Data Classification

- Data Classification is the process of categorizing data based on its sensitivity, value, and risk level so that appropriate security controls can be applied.
- It is a foundational control in cloud data security, governance, and compliance.
- Objectives of Data Classification
 - Apply appropriate security controls based on data sensitivity
 - Reduce risk of data breaches and leakage
 - Meet regulatory and compliance requirements
 - Enable efficient data handling, sharing, and retention



Data Classification Levels

Classification Level	Description	Examples	Typical Controls
Public	Information intended for public use	Website content, marketing material	Minimal controls
Internal	For internal business use	Policies, internal emails	Access control
Confidential	Sensitive business data	Financial reports, contracts	Encryption, RBAC
Restricted / Highly Confidential	Critical or regulated data	PII, PCI, PHI, credentials	Strong encryption, MFA, DLP



Data Classification in Cloud Environments

In cloud computing, data classification helps determine:

- Where data can be stored (region, service)
- How data must be encrypted
- Who can access the data
- Logging and monitoring requirements

Classification Based on Data Type

Personal Data:
Names, emails,
phone numbers
(PII)

Financial Data:
Credit card
numbers, bank
details

Healthcare Data:
Medical records
(PHI)

**Intellectual
Property:** Source
code, designs

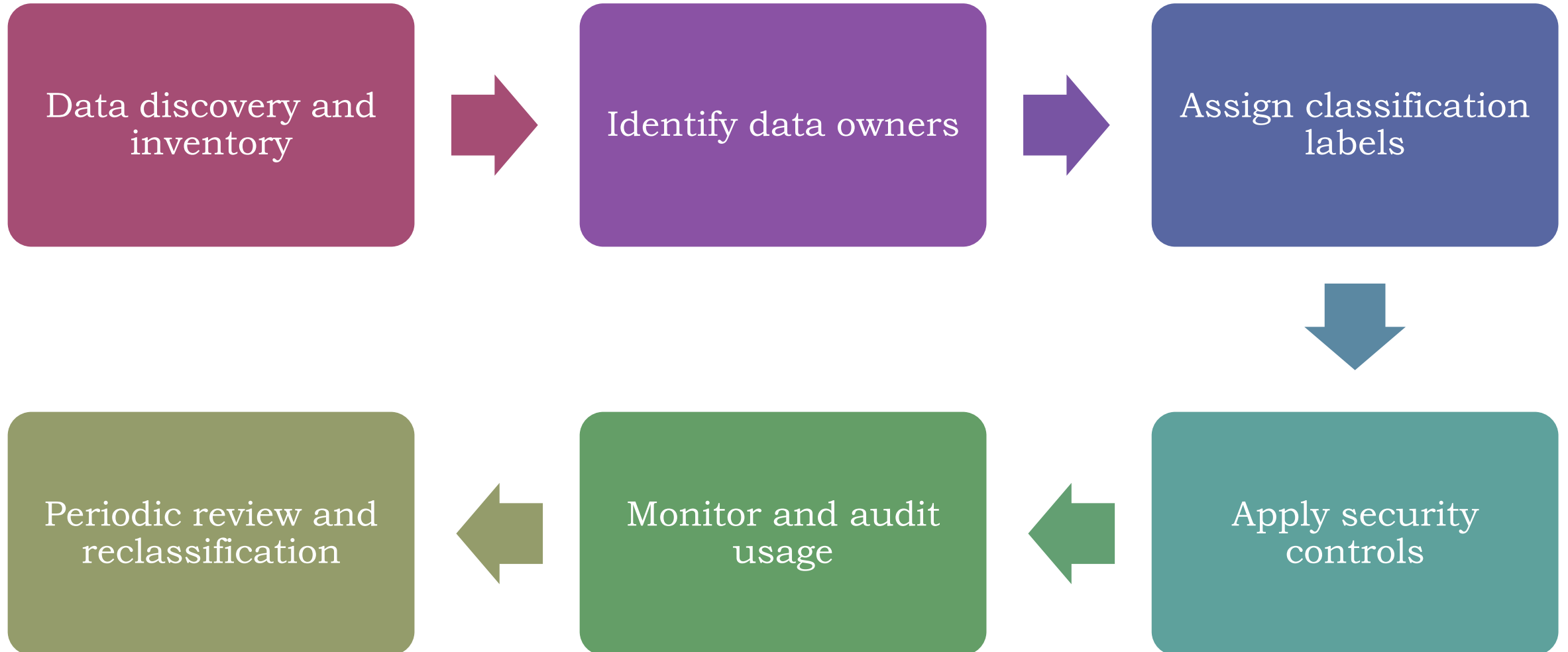
Operational Data:
Logs, metrics,
configurations



Classification Based on Data State

Data State	Description
Data at Rest	Stored data (databases, storage)
Data in Transit	Data moving over networks
Data in Use	Data being processed in memory

Data Classification Lifecycle



Data Identification

- Data Identification is the process of discovering, recognizing, and inventorying data assets across an organization so they can be classified, protected, monitored, and governed appropriately.
- It is the first and mandatory step before data classification, data protection, and compliance enforcement—especially in cloud environments.
- Purpose of Data Identification
 - Create visibility into what data exists and where it resides
 - Identify sensitive and regulated data
 - Assign data ownership
 - Support data classification, DLP, encryption, and compliance
 - Reduce risk from unknown or unmanaged data



Data Identification vs Data Classification

Aspect	Data Identification	Data Classification
Focus	Discovering data	Labeling data
Question Answered	What data do we have?	How sensitive is it?
Output	Data inventory	Data labels
Sequence	First step	Follows identification

What is Identified During Data Identification?

a. Data Location

- Cloud storage (object, block, file)
- Databases (SQL, NoSQL)
- SaaS applications
- Backups and snapshots
- Logs and archives

b. Data Type

- Structured (databases)
- Semi-structured (JSON, XML)
- Unstructured (documents, images, emails)

c. Data Content

- PII (names, emails, phone numbers)
- PCI (credit card data)
- PHI (medical data)
- Credentials, secrets, API keys
- Intellectual property

Data Identification in Cloud Environments

Cloud data identification focuses on:

- Multi-cloud and hybrid visibility
- Shadow IT and unmanaged storage
- Publicly exposed data
- Cross-region data movement

Techniques Used for Data Identification

- **Pattern Matching**

- Regular expressions for PII, PCI, PHI
- Keyword-based detection

- **Content Inspection**

- File and database scanning
- Deep content analysis

- **Metadata Analysis**

- File names, tags, labels
- Creation and access patterns

- **Machine Learning (Advanced)**

- Context-aware identification
- Reduces false positives

Data Identification Workflow

1. Define scope (cloud, on-prem, SaaS)
2. Discover data repositories
3. Scan and analyse data
4. Identify sensitive content
5. Build a centralized data inventory
6. Assign data owners
7. Feed results into classification and protection controls

Data Privacy

- Data Privacy refers to the proper handling, processing, storage, and protection of personal and sensitive information, ensuring that data is collected, used, shared, and retained lawfully, transparently, and securely.
- It focuses on individual rights over their data and how organizations manage that data.
- In short, Data Privacy is about respecting individual rights while responsibly managing data throughout its lifecycle.

Types of Data Covered Under Privacy

Data Type	Examples
Personal Data	Name, email, phone number
Sensitive Personal Data	Biometrics, health data
Financial Data	Bank account, credit card
Identity Data	Aadhaar, passport
Behavioral Data	Browsing history, location
Corporate Data	Employee and customer records

Why Data Privacy Is Important

- Protects individual rights
- Prevents identity theft and fraud
- Builds customer trust
- Ensures regulatory compliance
- Reduces legal and financial risk

Data Privacy Risks

- ✓ Unauthorized data access
- ✓ Excessive data collection
- ✓ Insider misuse
- ✓ Cloud misconfigurations
- ✓ Third-party data sharing

Data Privacy Regulations

- **GDPR** - *General Data Protection Regulation*
 - EU regulation that governs how organizations collect, process, store, and protect personal data of individuals.
- **CCPA / CPRA** - *California Consumer Privacy Act / California Privacy Rights Act*
 - California laws that grant consumers rights over their personal data and impose data protection obligations on businesses.
- **DPDP Act** - *Digital Personal Data Protection Act*
 - India's data protection law regulating the processing, consent, storage, and protection of personal digital data.
- **HIPAA** - *Health Insurance Portability and Accountability Act*
 - U.S. law that protects the privacy and security of individuals' medical and health information.
- **PCI DSS** - *Payment Card Industry Data Security Standard*
 - Global security standard that mandates controls to protect credit and debit cardholder data.



What is PII?

- PII (**Personally Identifiable Information**) refers to any data that can identify an individual directly or indirectly, such as name, address, ID numbers, financial data, or biometric information.
- Protecting PII requires a combination of administrative, technical, and physical controls across the data lifecycle.
- Effective PII protection requires layered controls across governance, technology, operations, and physical security.

Types of PII controls:

- **Administrative (Policy & Governance) Controls**

- These controls define rules, responsibilities, and processes.
 - Data classification and labeling policies
 - Privacy and acceptable-use policies

- **Technical Controls**

- These controls enforce protection through technology, like:
 - Access control – RBAC, MFA, PAM
 - Data protection – Encryption at rest and in transit.
 - Monitoring & Detection – Data Loss Prevention (DLP)
 - Application & Network Security - Secure API, WAF & API gateways

Types of PII controls:

- **Physical Controls**

- These controls protect physical access to PII.
 - Restricted access to data centers
 - Badge access and biometric controls

- **Operational Controls**

- These controls manage day-to-day handling of PII.
 - Secure data retention schedules
 - Automated data deletion

- **Cloud-Specific PII Controls**

- Identity-centric security (Zero Trust)
- CASB and CSPM
- Tenant isolation
- Data residency controls
- Secure configuration baselines

Azure Security Center

- Azure Security Center is now Microsoft Defender for Cloud.
- Microsoft Defender for Cloud is a *cloud-native security posture management (CSPM)* and *cloud workload protection platform (CWPP)* that helps you:
 - Assess security posture across Azure, AWS, GCP, and on-prem
 - Harden resources using security recommendations
 - Protect workloads with threat detection
 - Detect & Respond to active attacks
 - Comply with regulatory standards



Azure security capabilities

- Azure Key Vault
- Azure DDoS Protection
- Azure Firewall
- Azure confidential computing
- Microsoft Defender for Cloud (Azure Security Center)
- Azure Integrated HSM

Core Pillars of Defender for Cloud

- **Cloud Security Posture Management (CSPM)**
 - Ensures your environment follows security best practices.
 - Key functions:
 - Secure Score
 - Security Recommendations
 - Regulatory Compliance
 - Asset Inventory
 - Misconfiguration detection



Core Pillars of Defender for Cloud

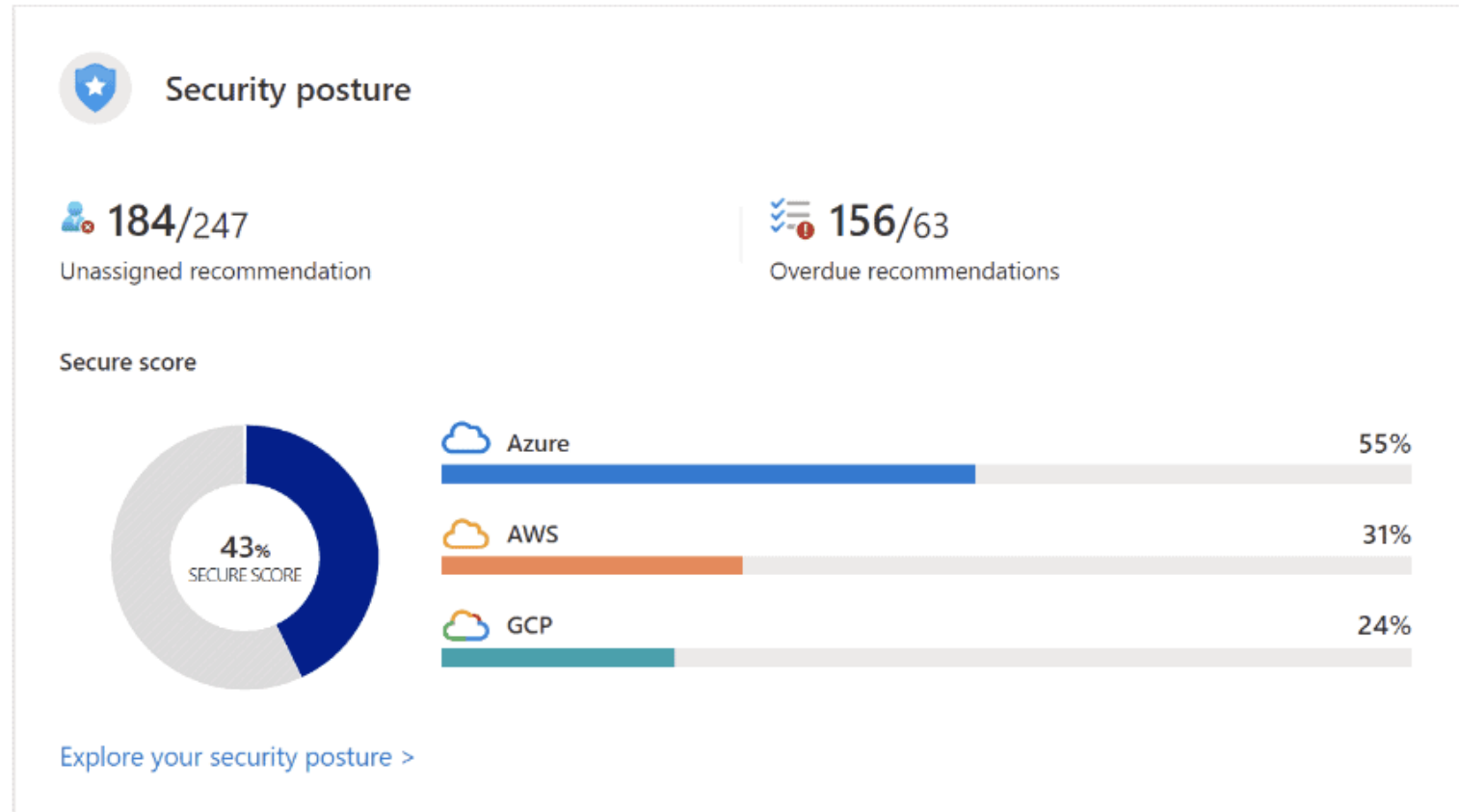
- Cloud Workload Protection (CWPP)
- Provides **runtime threat protection** for workloads:

Workload	Protection
Virtual Machines	Defender for Servers
Containers	Defender for Containers
Kubernetes	AKS protection
Databases	SQL, MySQL, PostgreSQL
Storage	Malware & data exfiltration detection
App Services	Web attack detection

Secure Score (Security Posture Score)

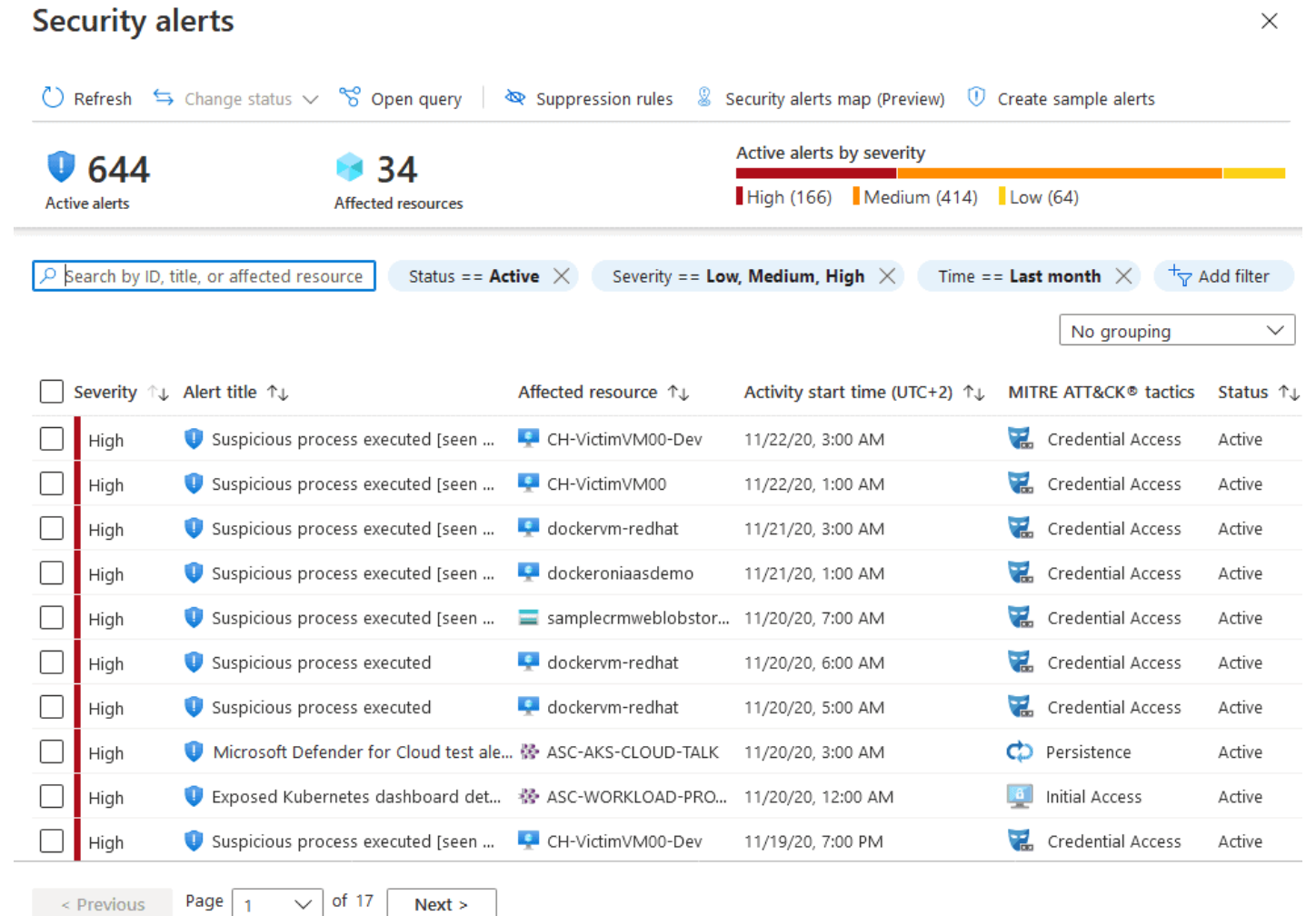
- A **numerical score (0–100)** representing your security posture.
- Secure Score is **risk-based**, not just compliance-based.

Recommendation	Points
Enable MFA	+10
Enable disk encryption	+6
Install endpoint protection	+8



Security Recommendations

- Configuration issues (NSGs open to Internet)
- Identity issues (No MFA on admins)
- Network exposure
- Missing protection
- OS hardening



Defender Plans (CWPP)

- **Defender for Servers**

- Threat detection on VMs
- File integrity monitoring
- Just-in-Time (JIT) VM access
- Endpoint Detection (EDR)
- Adaptive application controls

- **Defender for Storage**

- Malware scanning (near real-time)
- Sensitive data discovery
- Unusual access patterns
- Data exfiltration alerts

- **Defender for SQL**

- SQL injection detection
- Anomalous login detection
- Vulnerability assessments
- Works on:
 - Azure SQL
 - SQL on VM
 - Azure Arc-enabled SQL

- **Defender for Containers**

- Kubernetes runtime threat detection
- Image vulnerability scanning
- AKS & Arc-enabled K8s
- Integration with Microsoft Defender XDR

- **Defender for App Service**

- Web attack detection
- App behavior monitoring
- Integration with Defender for Endpoint

Threat Detection & Alerts

- Uses *Microsoft Threat Intelligence* + *behavioral analytics*.
- Alert Types:
 - Brute force attacks
 - Crypto-mining
 - Suspicious PowerShell
 - Privilege escalation
 - Malware execution
 - Data exfiltration
- Each alert includes:
 - MITRE ATT&CK mapping
 - Severity (Low–Critical)
 - Impact
 - Recommended actions
 - Attack timeline



Just-in-Time (JIT) VM Access

- Reduces attack surface by **closing management ports**.
- JIT lets you allow access to your VMs only when the access is needed, on the ports needed, and for the period of time needed
- **How it works:**
 - RDP/SSH closed by default
 - Access requested via Defender
 - Time-bound + IP restricted
 - Logged & audited
- **Ports protected:**
 - 22 (SSH)
 - 3389 (RDP)
 - Custom ports



Integration with Azure Services

- Azure Policy – enforce security at scale
- Azure Monitor & Log Analytics
- Microsoft Sentinel (SIEM/SOAR)
- Microsoft Defender XDR
- Azure Arc
- Entra ID (Azure AD)



Multi-cloud & Hybrid Support

- Defender for Cloud supports:
 - Azure
 - AWS
 - GCP
 - On-prem servers
- Using
 - Azure Arc
 - Cloud connectors
 - Centralized posture management







That's all Folks!